

IPsec Sentinel assessment

04-estate.pcap · baseline nist_800_77r1 · generated 2026-09-07 09:50 UTC · 0.1.0 (d433717-dirty)

Summary

Of the 3 tunnels examined, 2 are protected by cryptography that is no longer considered safe, and should be changed. The estate scores 33 out of 100 (grade F).

Estate score	33 / 100 (grade F)
Tunnels assessed	3
Undocumented tunnels	1
Verified findings (Section A)	17
Inferred findings (Section B)	0
Critical	4
High	6
Medium	4
Informational	3

- 1 tunnel carrying traffic is not on the documented list. An undocumented tunnel is one nobody is maintaining.
- 17 findings in Section A are read directly from the negotiation and can be relied on as evidence. 0 findings in Section B are estimated from traffic patterns and carry a stated confidence.

How to read this report. **Section A** contains findings read directly from the negotiation as it happened on the wire. They are facts and carry no confidence value, because none is needed. **Section B** contains findings estimated from traffic patterns by a statistical model. Every one states a confidence, and none of them is evidence in the sense Section A is. The two are never mixed.

Section A — verified findings

Read from the negotiation. Deterministic; no confidence value applies.

SECTION A — VERIFIED

Critical · CRY-02 — Diffie-Hellman group 2 (1024-bit MODP) offered

Tunnel

828e1abb53c8

Evidence

1024-bit MODP offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-57 Part 1 Rev. 5, Table 2

ATT&CK

T1600.001

Remediation

Remove group 2 (modp1024) from the IKE proposal. 1024-bit MODP is within reach of a precomputation attack against a reused prime; use group 19 (ecp256) or group 14 (modp2048) at minimum.

SECTION A — VERIFIED

Critical · IKE-03 — IKEv1 Aggressive Mode with pre-shared key authentication

Tunnel

828e1abb53c8

Evidence

IKEv1 Aggressive Mode with pre-shared key authentication between 198.51.100.10 and 203.0.113.11. The pre-shared key hash is exposed to any passive observer and can be cracked offline. Treat this PSK as compromised.

Standard

RFC 2409 section 5.4; NIST SP 800-77 Rev. 1 section 5.1

ATT&CK

T1110.002

Remediation

Rotate the pre-shared key immediately and disable Aggressive Mode. Rotating without disabling the mode only restarts the clock, since the next handshake exposes the new key the same way. Prefer certificate authentication, or IKEv2 where the authentication payload is encrypted.

SECTION A — VERIFIED**High · CRY-05 — 3DES encryption offered****Tunnel**

828e1abb53c8

Evidence

3DES_CBC offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-131A Rev. 2 (disallowed after 2023)

ATT&CK

T1600.001

Remediation

Remove 3DES from the proposals. Its 64-bit block size makes it vulnerable to birthday-bound collision attacks (Sweet32) on long-lived connections, and NIST disallowed it for new use after 2023. Use AES-GCM-256.

SECTION A — VERIFIED**High · CRY-06 — MD5 integrity offered****Tunnel**

828e1abb53c8

Evidence

MD5 offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-131A Rev. 2

ATT&CK

T1600.001

Remediation

Remove AUTH_HMAC_MD5_96 from the proposals. Use AUTH_HMAC_SHA2_256_128 or stronger.

SECTION A — VERIFIED**High · CRY-11 — Diffie-Hellman group weaker than the baseline requires****Tunnel**

828e1abb53c8

Evidence

1024-bit MODP (80-bit security strength) offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-57 Part 1 Rev. 5, Table 2

ATT&CK

T1600.001

Remediation

Raise the Diffie-Hellman group to meet the baseline's required strength. Unlike the fixed-group rules, this threshold comes from the selected compliance baseline, so the acceptable group depends on the policy in force.

SECTION A — VERIFIED**Medium · IKE-01 — IKEv1 in use****Tunnel**

828e1abb53c8

Evidence

the negotiation used IKEv1 (Aggressive Mode) between 198.51.100.10 and 203.0.113.11

Standard

RFC 8247 section 2.4; RFC 9395 deprecates IKEv1

Remediation

Migrate this tunnel to IKEv2. IKEv1 was deprecated by RFC 9395 and lacks IKEv2's built-in DoS protection, MOBIKE and cleaner rekeying.

SECTION A — VERIFIED**Medium · SA-01 — IKE SA lifetime longer than 24 hours****Tunnel**

828e1abb53c8

Evidence

the IKE SA lifetime is 95040 s (26.4 h), over the 86400 s (24.0 h) limit (read from the IKE handshake as an IKEv1 phase 1 SA attribute)

Standard

NIST SP 800-77 Rev. 1 section 5.1

Remediation

Reduce the IKE SA lifetime to 24 hours or less. A long-lived SA widens the window in which a compromised key remains useful.

SECTION A — VERIFIED**Informational · PQC-01 — Not resistant to harvest-now-decrypt-later (at_risk)****Tunnel**

828e1abb53c8

Evidence

classical key exchange only (1024-bit MODP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this

Standard

RFC 9370; RFC 8784; NIST FIPS 203

ATT&CK

T1040

Remediation

Enable a hybrid post-quantum key exchange (RFC 9370 additional key exchange with ML-KEM), or an RFC 8784 post-quantum pre-shared key where the peers already share a secret. Prioritise tunnels carrying data whose confidentiality must outlast the arrival of quantum hardware — remediation later does not protect traffic recorded today.

SECTION A — VERIFIED**Critical · CRY-02 — Diffie-Hellman group 2 (1024-bit MODP) offered****Tunnel**

766f2e38dc23

Evidence

1024-bit MODP offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-57 Part 1 Rev. 5, Table 2

ATT&CK

T1600.001

Remediation

Remove group 2 (modp1024) from the IKE proposal. 1024-bit MODP is within reach of a precomputation attack against a reused prime; use group 19 (ecp256) or group 14 (modp2048) at minimum.

SECTION A — VERIFIED**Critical · IKE-03 — IKEv1 Aggressive Mode with pre-shared key authentication****Tunnel**

766f2e38dc23

Evidence

IKEv1 Aggressive Mode with pre-shared key authentication between 198.51.100.10 and 203.0.113.10. The pre-shared key hash is exposed to any passive observer and can be cracked offline. Treat this PSK as compromised.

Standard

RFC 2409 section 5.4; NIST SP 800-77 Rev. 1 section 5.1

ATT&CK

T1110.002

Remediation

Rotate the pre-shared key immediately and disable Aggressive Mode. Rotating without disabling the mode only restarts the clock, since the next handshake exposes the new key the same way. Prefer certificate authentication, or IKEv2 where the authentication payload is encrypted.

SECTION A — VERIFIED**High · CRY-05 — 3DES encryption offered****Tunnel**

766f2e38dc23

Evidence

3DES_CBC offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-131A Rev. 2 (disallowed after 2023)

ATT&CK

T1600.001

Remediation

Remove 3DES from the proposals. Its 64-bit block size makes it vulnerable to birthday-bound collision attacks (Sweet32) on long-lived connections, and NIST disallowed it for new use after 2023. Use AES-GCM-256.

SECTION A — VERIFIED**High · CRY-06 — MD5 integrity offered****Tunnel**

766f2e38dc23

Evidence

MD5 offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-131A Rev. 2

ATT&CK

T1600.001

Remediation

Remove AUTH_HMAC_MD5_96 from the proposals. Use AUTH_HMAC_SHA2_256_128 or stronger.

SECTION A — VERIFIED**High · CRY-11 — Diffie-Hellman group weaker than the baseline requires****Tunnel**

766f2e38dc23

Evidence

1024-bit MODP (80-bit security strength) offered in proposal 1 of 1, selected in this session

Standard

NIST SP 800-57 Part 1 Rev. 5, Table 2

ATT&CK

T1600.001

Remediation

Raise the Diffie-Hellman group to meet the baseline's required strength. Unlike the fixed-group rules, this threshold comes from the selected compliance baseline, so the acceptable group depends on the policy in force.

SECTION A — VERIFIED**Medium · IKE-01 — IKEv1 in use****Tunnel**

766f2e38dc23

Evidence

the negotiation used IKEv1 (Aggressive Mode) between 198.51.100.10 and 203.0.113.10

Standard

RFC 8247 section 2.4; RFC 9395 deprecates IKEv1

Remediation

Migrate this tunnel to IKEv2. IKEv1 was deprecated by RFC 9395 and lacks IKEv2's built-in DoS protection, MOBIKE and cleaner rekeying.

SECTION A — VERIFIED**Medium · SA-01 — IKE SA lifetime longer than 24 hours****Tunnel**

766f2e38dc23

Evidence

the IKE SA lifetime is 95040 s (26.4 h), over the 86400 s (24.0 h) limit (read from the IKE handshake as an IKEv1 phase 1 SA attribute)

Standard

NIST SP 800-77 Rev. 1 section 5.1

Remediation

Reduce the IKE SA lifetime to 24 hours or less. A long-lived SA widens the window in which a compromised key remains useful.

SECTION A — VERIFIED**Informational · PQC-01 — Not resistant to harvest-now-decrypt-later (at_risk)****Tunnel**

766f2e38dc23

Evidence

classical key exchange only (1024-bit MODP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this

Standard

RFC 9370; RFC 8784; NIST FIPS 203

ATT&CK

T1040

Remediation

Enable a hybrid post-quantum key exchange (RFC 9370 additional key exchange with ML-KEM), or an RFC 8784 post-quantum pre-shared key where the peers already share a secret. Prioritise tunnels carrying data whose confidentiality must outlast the arrival of quantum hardware — remediation later does not protect traffic recorded today.

SECTION A — VERIFIED**Informational · PQC-01 — Not resistant to harvest-now-decrypt-later (at_risk)****Tunnel**

da10571d54a2

Evidence

classical key exchange only (384-bit ECP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this

Standard

RFC 9370; RFC 8784; NIST FIPS 203

ATT&CK

T1040

Remediation

Enable a hybrid post-quantum key exchange (RFC 9370 additional key exchange with ML-KEM), or an RFC 8784 post-quantum pre-shared key where the peers already share a secret. Prioritise tunnels carrying data whose confidentiality must outlast the arrival of quantum hardware — remediation later does not protect traffic recorded today.

Section B — inferred findings

Estimated from traffic patterns. Every entry states its confidence and is not compliance evidence.

No inferred findings.

Inventory

Tunnel	Endpoints	Status	Suite	Packets
828e1 abb53 c8	198.51.100. 10 ↔ 203.0.113.1 1	documented	3DES_CBC / MD5 / 1024-bit MODP	170
766f2 e38dc2 3	198.51.100. 10 ↔ 203.0.113.1 0	undocumented	3DES_CBC / MD5 / 1024-bit MODP	2998

da1057 1d54a2	198.51.100.10 ↔ 203.0.113.12	documented	ENCR_AES_CBC-256 / AUTH_HMAC_SHA2_384_192 / PRF_HMAC_SHA2_384 / 384-bit ECP	3000
------------------	---------------------------------	------------	---	------

What encryption does not hide

Every tunnel below is listed regardless of how well it is configured. Encryption protects the contents of a conversation, not the fact that it happened, who took part, when, or how much was said.

Tunnel	Endpoints	Volume	Sessions	Active hours	Inferred application
828e1ab b53c8	198.51.100.10 ↔ 203.0.113.11	53.6 kB in 170 packets	2	15:00	email INFERRED 0.99
766f2e38 dc23	198.51.100.10 ↔ 203.0.113.10	695.6 kB in 2998 packets	2	09:00	voip INFERRED 1.00
da10571 d54a2	198.51.100.10 ↔ 203.0.113.12	348.0 kB in 3000 packets	2	09:00	voip INFERRED 1.00

Threat matrix

Technique	Severity	Tunnels	Findings	Published vulnerabilities
-----------	----------	---------	----------	---------------------------

T1110.002 — Brute Force: Password Cracking	Critical	766f2e38 dc23, 828e1abb5 3c8	IKE-03	CVE-2018-5389 (CVSS 5.9) IKEv1 pre-shared key authentication is open to an offline dictionary attack, recovering a weak key or allowing host impersonation. <i>Scope:</i> The published record describes IKEv1 main mode. Aggressive mode is the same attack under worse conditions — the authentication hash is sent before encryption begins, so an observer needs only one captured handshake rather than an active position. https://nvd.nist.gov/vuln/detail/CVE-2018-5389
T1600.001 — Weaken Encryption: Reduce Key Space	Critical	766f2e38 dc23, 828e1abb5 3c8	CRY-02, CRY-05, CRY-06, CRY-11	CVE-2016-2183 (CVSS 7.5) Birthday attacks against 64-bit block ciphers recover plaintext from long-lived encrypted sessions. <i>Scope:</i> The published record names IPsec explicitly alongside TLS and SSH, so it applies directly to a 3DES ESP or IKE proposal. https://nvd.nist.gov/vuln/detail/CVE-2016-2183
T1040 — Network Sniffing	Informational	766f2e38 dc23, 828e1abb5 3c8, da10571d5 4a2	PQC-01	<i>none catalogued</i>

Findings with no ATT&CK technique mapped, listed so the matrix is not read as complete: IKE-01, SA-01.

Post-quantum readiness

Traffic captured today can be stored and decrypted later by an adversary with a cryptographically relevant quantum computer. Readiness is about traffic already on the wire, not only about future sessions.

Tunnel	Grade	Reasoning
828e1a bb53c8	at_risk	classical key exchange only (1024-bit MODP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this
766f2e3 8dc23	at_risk	classical key exchange only (1024-bit MODP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this
da10571 d54a2	at_risk	classical key exchange only (384-bit ECP), so traffic recorded today is decryptable in retrospect once the hardware exists. The forward secrecy setting was not supplied and is not visible to a passive observer, so EXPOSED cannot be excluded — supply it to resolve this

Remediation

No change packages were included in this report.

Enrichment ran with reduced reference data: vendor CVE enrichment is unavailable — no local CVE cache was found, so this report lists no product-specific advisories. The protocol CVEs in the threat matrix are built in and unaffected, and every finding in this report was produced without them.

Generated by 0.1.0 (d433717-dirty) against baseline nist_800_77r1. Report schema 1.3.

This tool reads captured traffic and produces documents. It never writes to a network device and stores no credential. Every configuration it generates is applied by a person who has reviewed it.